Практическое занятие №2. Анализ рисков

Асадчий Константин Михайлович, группа 23ис-41

Вариант Г. Медицинская информационная система

МИС используется в городской поликлинике для записи пациентов и ведения электронных медицинских карт. С ней работают регистраторы, врачи, сотрудники лаборатории и администратор. Критичны доступ к карте, правильное сохранение назначений и защита данных пациентов. Система работает в локальной сети поликлиники и обменивается сведениями с внешними сервисами. В начале смены число запросов возрастает. При недоступности МИС сотрудники временно фиксируют сведения по резервному порядку и после восстановления сверяют записи.

Условия оценки

Это учебная оценка на один год, а не аудит настоящей поликлиники. Предполагается один основной сервер, один канал интернета, вход по паролю и отсутствие проверенного восстановления. Баллы вероятности и последствий выбраны качественно по шкале задания. Риск R = B × T: 1–4 — низкий, 5–9 — средний, 10–15 — высокий, 16–25 — критический. Для примера приемлем уровень не выше 9 при назначенном ответственном и контроле; это условное правило работы, не отраслевой норматив.

1. Идентификация рисков

ID	Описание риска	Объект уязвимости	Угроза
R-01	Вирус-шифровальщик блокирует карты пациентов	Программный, информационный	Блокирование, потеря целостности
R-02	Похищена учётная запись, выгружены данные пациентов	Человеческий, информационный	Утечка
R-03	Отказ диска сервера с основной базой	Аппаратный, информационный	Отказ, потеря данных
R-04	Отключение электричества останавливает сервер	Аппаратный	Отказ, блокирование
R-05	Сотрудник меняет запись не того пациента	Человеческий, информационный	Ошибка, потеря целостности
R-06	Неудачное обновление нарушает работу МИС	Программный	Сбой, блокирование
R-07	Утренняя нагрузка замедляет запись на приём	Программный, аппаратный	Блокирование
R-08	Обрыв интернета нарушает обмен с внешними сервисами	Аппаратный	Сбой, блокирование
R-09	Перегрев сервера вызывает остановку	Аппаратный	Отказ
R-10	Принтер регистратуры не печатает талон	Аппаратный	Отказ

2. Оценка рисков и меры

ID	Риск	В и обоснование	Т и обоснование	В × Т	Зона	Мера и её тип	Стратегия	Ожидаемый эффект
R-01	Вирус-шифровальщик блокирует карты пациентов	4. Почта и внешние файлы используются ежедневно; предполагается слабая защита рабочих мест	5. Недоступны карты, назначения и результаты; возможна потеря данных	20	Критический	Программная: защита рабочих мест, обновления, отдельные неизменяемые копии; организационная: обучение	Снижение	Меньше заражений; восстановление из проверенной копии
R-02	Похищена учётная запись, выгружены данные пациентов	4. При входе только по паролю фишинг и повторное использование паролей вероятны	4. Раскрытие персональных сведений, расходы на расследование и ущерб доверию	16	Критический	Программная: двухфакторный вход и минимальные права; организационная: проверка доступов	Снижение	Сложнее войти по украденному паролю и выгрузить всю базу
R-03	Отказ диска сервера с основной базой	3. Оборудование работает круглосуточно и изнашивается; резервирование не предполагается	5. Без пригодной копии возможна потеря карт и истории назначений	15	Высокий	Техническая: зеркальные диски и контроль состояния; программная: резервные копии и проверка восстановления	Снижение	Одиночный отказ диска не уничтожает данные; базу можно восстановить
R-04	Отключение электричества останавливает сервер	3. Перебои питания возможны; в исходном примере нет ИБП	4. Прерывается приём пациентов, возможны незавершённые записи	12	Высокий	Техническая: ИБП, контроль питания и штатное выключение	Снижение	Краткий перебой не останавливает сервер; при долгом данные сохраняются
R-05	Сотрудник меняет запись не того пациента	3. Однотипные фамилии и спешка повышают вероятность неверного выбора	4. Неверная запись мешает работе врача и требует срочной сверки	12	Высокий	Программная: два признака пациента, подтверждение правок и журнал; организационная: сверка перед сохранением	Снижение	Ошибочный выбор заметнее, изменения можно найти и отменить

В — вероятность, Т — тяжесть. Например, для R-01: 4 × 5 = 20, критическая зона. Меры указаны как предложения для рассматриваемого примера.

2. Оценка рисков и меры — продолжение

ID	Риск	В и обоснование	Т и обоснование	В × Т	Зона	Мера и её тип	Стратегия	Ожидаемый эффект
R-06	Неудачное обновление нарушает работу МИС	3. В исходном примере нет отдельной тестовой среды и плана отката	4. Часть функций не работает, задерживается приём и оформление документов	12	Высокий	Программная: тестовая среда, копия перед обновлением и откат; организационная: окно обслуживания	Снижение	Проблемы выявляются заранее, рабочая версия восстанавливается быстрее
R-07	Утренняя нагрузка замедляет запись на приём	3. В начале смены много одновременных запросов	3. Растут очереди и время ожидания, но данные остаются доступны	9	Средний	Программная: нагрузочный тест и оптимизация запросов; техническая: контроль ресурсов	Снижение	Задержки выявляются до пикового часа и уменьшаются
R-08	Обрыв интернета нарушает обмен с внешними сервисами	3. Используется один канал связи, аварии провайдера возможны	3. Внешние запросы задерживаются, внутренний учёт можно продолжать	9	Средний	Техническая: второй канал; программная: очередь запросов; организационная: порядок работы при обрыве	Снижение	Часть обмена переключается на резерв, запросы повторяются после восстановления
R-09	Перегрев сервера вызывает остановку	2. Перегрев редок, но возможен из-за пыли или неисправного охлаждения	4. Остановка сервера задерживает работу отделений и требует ремонта	8	Средний	Техническая: датчики и исправное охлаждение; организационная: очистка и проверка помещения	Снижение	Температуру контролируют, проблему обнаруживают до аварийного отключения
R-10	Принтер регистратуры не печатает талон	3. Расходники заканчиваются, возможны замятия бумаги	2. Теряется немного времени; запись на приём и электронные карты работают	6	Средний	Организационная: запас бумаги и порядок перехода на соседний принтер	Принятие	Остаточные задержки допустимы, дорогое дублирование каждого принтера не требуется

В — вероятность, Т — тяжесть. Например, для R-01: 4 × 5 = 20, критическая зона. Меры указаны как предложения для рассматриваемого примера.

3. Остаточный риск

Выбраны три самых высоких исходных риска: 20, 16 и 15. Ниже приведена прогнозная оценка после предполагаемого внедрения мер. Фактическое внедрение и измерение в настоящей МИС не проводились.

ID и риск	Исходный уровень	Предполагаемые внедрённые меры	Новый уровень	Приемлемость и условие
R-01. Шифровальщик	4 × 5 = 20	Защита рабочих мест, обновления, обучение, отдельные неизменяемые копии и тест восстановления	2 × 4 = 8; средний	Условно да: восстановление проверено, ответственный — администратор. Последствия остаются высокими из-за простоя
R-02. Утечка через учётную запись	4 × 4 = 16	Двухфакторный вход, минимальные права, обучение и контроль выгрузок	2 × 4 = 8; средний	Условно да: доступы пересматриваются. Тяжесть не снижается: случившуюся утечку нельзя отменить
R-03. Отказ диска	3 × 5 = 15	Зеркальные диски, мониторинг, отдельные копии базы и регулярное восстановление на тестовом сервере	2 × 3 = 6; средний	Условно да: копии доступны и пригодны. Остались затраты времени на переключение и восстановление

Зеркальные диски повышают доступность, но не заменяют резервные копии: удаление или шифрование может затронуть оба диска. Средний остаточный риск требует внимания и пересмотра, а не считается полностью устранённым.

4. Вывод

Самыми опасными оказались шифровальщик, утечка через учётную запись и отказ диска: их уровни равны 20, 16 и 15. Они могут нарушить доступ к картам или раскрыть данные пациентов. По прогнозу, предложенные меры снижают эти риски до 8, 8 и 6 баллов. В рамках принятого учебного правила такие уровни условно приемлемы при постоянном контроле. Больше всего внимания требуют проверка восстановления, актуальные права доступа и обучение сотрудников. Оценку нужно повторять после изменений системы, инцидентов и проверки реальной эффективности мер.